

Seguridad Informática - Trabajo Grupal Final

Parte 1 - Caso de Empresa

A continuación, se presenta una empresa ficticia con numerosas debilidades y vulnerabilidades relacionadas con la ciberseguridad:

Nombre de la empresa: *TechNow Solutions S.A.*

Descripción de la empresa: TechNow Solutions es una empresa tecnológica emergente que se dedica a ofrecer soluciones de software personalizadas para pequeñas y medianas empresas (pymes). Su principal producto es una plataforma en la nube que permite gestionar las relaciones con los clientes, ventas y el inventario (Sistema ERP/CRM). La empresa tiene un equipo de desarrollo pequeño y está en pleno crecimiento, pero no tiene experiencia ni recursos suficientes en términos de ciberseguridad.

Debilidades y Vulnerabilidades en Ciberseguridad:

1. **Falta de una política de seguridad formalizada:** La empresa no tiene un protocolo claro de seguridad informática o políticas internas de ciberseguridad. Los empleados no reciben formación sobre prácticas seguras en línea, como la creación de contraseñas fuertes o el manejo de datos sensibles.
2. **Contraseñas débiles y mal gestionadas:** Los empleados usan contraseñas simples y muchas veces reutilizan las mismas para diferentes servicios. No existe un sistema de autenticación multifactor (MFA) en ninguna de las plataformas que se utilizan, ni una política de cambio de contraseñas periódicas.
3. **Falta de encriptación de datos sensibles:** Los datos de los clientes (como información personal y financiera) se almacenan en bases de datos sin cifrado, lo que facilita el acceso no autorizado en caso de un ataque.
4. **Infraestructura tecnológica desactualizada:** Los servidores de la empresa están ejecutando versiones antiguas de software que no se actualizan regularmente. Esto hace que la infraestructura sea vulnerable a ataques conocidos, como aquellos que explotan vulnerabilidades no parcheadas.
5. **La Infraestructura y arquitectura de la red física y lógica no está estructurada:** La infraestructura y la arquitectura de la red no se encuentra dividida en zonas para acceso público y acceso privado.
6. **Uso de software sin licencia o inseguro:** El equipo de desarrollo utiliza software de código abierto y herramientas sin verificar adecuadamente su seguridad o autenticidad. En algunos casos, se usan programas de software pirateado que pueden estar comprometidos con malware.
7. **Accesos no controlados o restringidos:** No existe un sistema adecuado de control de accesos basado en el principio de "mínimos privilegios". Los empleados tienen acceso a recursos y sistemas que

no son necesarios para su trabajo, lo que aumenta el riesgo de un acceso malintencionado o accidental a información crítica.

8. **Redes no protegidas adecuadamente:** La empresa no tiene una red de seguridad bien configurada, como firewalls o sistemas de detección de intrusos (IDS/IPS). Los dispositivos de la red (como routers y switches) no están protegidos adecuadamente con contraseñas seguras ni configuraciones actualizadas.
9. **Sin monitoreo constante de amenazas:** No hay un equipo dedicado a la monitorización de ciberamenazas o un sistema de detección de intrusos (IDS). La empresa no está preparada para detectar actividades inusuales en sus sistemas hasta que ya se haya producido un daño importante.
10. **Respaldo de datos inadecuado:** No existe un sistema de respaldo automático y seguro para los datos, lo que significa que si ocurre un ataque de ransomware o pérdida de datos, la empresa podría perder información valiosa sin posibilidad de recuperación.
11. **Políticas de privacidad y protección de datos débiles:** La empresa no cumple con las normativas de privacidad de datos, ya que no tiene un marco claro de protección de la información personal de los clientes. Tampoco informa adecuadamente a los usuarios sobre cómo se usan y almacenan sus datos.
12. **Dependencia de terceros no verificados:** La empresa utiliza varios servicios en la nube y proveedores externos sin verificar la seguridad de sus plataformas ni exigirles estándares de seguridad rigurosos, lo que abre posibles puertas de entrada para atacantes.
13. **Inadecuada formación de empleados:** Los empleados no reciben capacitación regular sobre ciberseguridad, lo que hace que sean vulnerables a ataques de phishing, ingeniería social o descargas de archivos maliciosos. Además, se permite el uso de dispositivos personales (BYOD: Bring Your Own Device) sin ningún tipo de control.
14. **Riesgos en dispositivos móviles y de acceso remoto:** La empresa no aplica ninguna política de gestión de dispositivos móviles. Los empleados pueden acceder a información sensible desde sus teléfonos o laptops personales, lo que aumenta el riesgo de pérdida o robo de datos. También pueden acceder libremente a los servicios internos de la empresa, desde puntos remotos sin ningún tipo de restricción.
15. **Falta de un plan de respuesta ante incidentes:** No existe un plan estructurado para hacer frente a un ataque cibernético o una brecha de seguridad. Si se produce un incidente de seguridad, la empresa no sabe cómo actuar, lo que retrasa la recuperación y aumenta el impacto.
16. **Vulnerabilidad frente a ataques de denegación de servicio (DDoS):** TechNow Solutions no tiene protecciones contra ataques DDoS (Distributed Denial of Service), lo que hace que su plataforma sea susceptible a este tipo de ataques, que pueden paralizar sus servicios en línea.
17. **Seguridad física deficiente:** Los servidores y equipos de almacenamiento están ubicados en oficinas sin medidas de seguridad física (como control de acceso con tarjetas o cámaras de vigilancia), lo que facilita el acceso no autorizado a la infraestructura tecnológica de la empresa.

Impacto Potencial:

- **Riesgo de robo de datos sensibles:** Los atacantes pueden robar información crítica de clientes, lo que daña la reputación de la empresa.
- **Pérdida financiera:** Un ataque de ransomware o un fallo de seguridad podría resultar en pérdidas económicas significativas debido a la interrupción de los servicios o el pago de rescates.
- **Cumplimiento normativo:** La empresa podría enfrentar sanciones por no cumplir con regulaciones de protección de datos y privacidad.
- **Confianza de los clientes:** Las vulnerabilidades en seguridad pueden erosionar la confianza de los clientes, quienes pueden elegir a competidores más seguros.

Esta empresa ficticia refleja una situación bastante común en empresas pequeñas y medianas (PYMES) que crecen rápidamente sin implementar medidas de seguridad adecuadas.

Entregable:

Documento PDF con:

- Propuestas de solución para cada uno de los puntos débiles y vulnerabilidades mencionados (17)
- Arquitectura óptima de la red física y lógica
- Tipos de Testings a realizar y tipos de Teams propuestos (equipo de especialistas en Ciberseguridad)
- Cumplimiento de Normas: Completar Formulario ISO 27000

Parte 2 - Simulación de servicios de red con máquinas virtuales

Entregable:

Implementación de Hosts con Virtualbox según lo siguiente:

Host Externo (Windows 10/11 o Linux) ↔ Firewall / IDS (Linux CentOS) ↔ Host Interno (Windows 10/11)

- Implementar un servidor Firewall e IDS (Intrusion Detection System)
- Implementar una VPN entre un host Externo y un host Interno

